

Security Assessment Report: Apache Web Server (Task 4)

Target: Localhost (127.0.0.1)

Server Version: Apache/2.4.65 (Debian)

1. Services Detected

Port	Service	Version
80	HTTP	Apache/2.4.65 (Debian)
5432	PostgreSQL DB	Version 15.2 - 15.4

Vulnerabilities Identified

1. Missing Security Headers

Nikto Findings:

- X-Frame-Options header is missing → Prone to Clickjacking.
- X-Content-Type-Options is missing → Browser MIME-sniffing may occur.

Curl Output Confirms:

Only minimal headers are returned — no security-specific headers included.

2. Server ETag Leaks Inode Info

Nikto Alert:

ETag header reveals inode and modification details, which may help attackers fingerprint the server or content.

- Example:
 - ETag: "29cd-60474c69373a0"
-

3. Information Disclosure via /server-status

- The /server-status page is publicly accessible.
- Reveals real-time data about server processes.
- Could be leveraged in targeted attacks or reconnaissance.

4. Allowed HTTP Methods: OPTIONS, HEAD, GET, POST

Nikto Finding:

The server accepts OPTIONS method. While not dangerous by itself, it may reveal supported methods to attackers.

Defense Implementation

A. Harden Apache Security Headers

Edit the file:

```
sudo nano /etc/apache2/conf-available/security.conf
```

Add or uncomment these lines:

```
# Prevent Clickjacking
```

```
Header always set X-Frame-Options "SAMEORIGIN"
```

```
# Prevent MIME-sniffing
```

```
Header set X-Content-Type-Options "nosniff"
```

```
# Prevent XSS in older browsers
```

```
Header set X-XSS-Protection "1; mode=block"
```

```
# Strict Transport Security (if using HTTPS)
```

```
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
```

Enable the headers module:

```
sudo a2enmod headers
```

```
sudo systemctl restart apache2
```

B. Disable ETag to Prevent Info Leakage

Edit config:

```
sudo nano /etc/apache2/apache2.conf
```

Add at the end:

```
FileETag None
```

Then restart:

```
sudo systemctl restart apache2
```

✓ C. Restrict Access to /server-status

Edit the file:

```
sudo nano /etc/apache2/mods-enabled/status.conf
```

Modify to allow access **only from localhost (optional)**:

```
<Location "/server-status">
```

```
    SetHandler server-status
```

```
    Require ip 127.0.0.1
```

```
</Location>
```

Restart Apache:

```
sudo systemctl restart apache2
```

Or completely disable:

```
sudo a2dismod status
```

```
sudo systemctl restart apache2
```

✓ D. Limit HTTP Methods (Optional)

Use the following in Apache config or virtual host:

```
<LimitExcept GET POST>
```

```
    Deny from all
```

```
</LimitExcept>
```

✓ E. Keep Server Updated

While Apache 2.4.65 is recent, ensure your system performs regular updates:

```
sudo apt update
```

```
sudo apt upgrade
```

Summary Table

Vulnerability	Risk Level	Recommendation
Missing Security Headers	Medium	Add X-Frame, X-Content, etc. headers
ETag Inode Exposure	Low	Disable ETag via config
/server-status Public	High	Restrict or disable module
OPTIONS Method Enabled	Low	Restrict unused HTTP methods
Apache Version Disclosure	Informational	Use ServerTokens & ServerSignature configs

Adding these lines to </etc/apache2/conf-available/security.conf> to **hide version info**:

```
ServerTokens Prod
```

```
ServerSignature Off
```

```
(comment on and uncomment off)
```

Conclusion

My server is functional but exposes multiple informational and moderate-risk vulnerabilities. By applying the above configurations, it will significantly **harden my server against reconnaissance, clickjacking, MIME-based attacks, and information leaks.**